

Dokumen Kompilasi Laporan Teknis Akhir Kelompok 8

Perancangan dan Implementasi Protokol Keamanan AAA

Pada Sistem Informasi Seekem

Muhammad Abyan Putra Wibowo	G6401231078
Muhammad Agung Rizkiansyah	G6401231096
Muhammad Chalied Al Walid	G6401231114

1. Pendahuluan

1.1. Latar Belakang

Di lingkungan kampus IPB University, insiden kehilangan maupun penemuan barang pribadi merupakan hal yang kerap terjadi. Informasi mengenai barang-barang tersebut umumnya hanya tersebar melalui media sosial atau grup obrolan yang tidak terstruktur, sehingga menyulitkan proses pencarian, pelacakan status, dan verifikasi kepemilikan. Selain itu, proses serah terima barang temuan secara konvensional rentan terhadap klaim palsu serta risiko penyalahgunaan data kontak pribadi apabila disebarluaskan tanpa mekanisme pengamanan.

Untuk mengatasi permasalahan tersebut, dikembangkan platform SEEKEM yang menerapkan prinsip keamanan informasi secara menyeluruh, dengan fokus utama pada implementasi kerangka kerja AAA (Authentication, Authorization, Accounting), perlindungan data pribadi melalui enkripsi, serta integritas catatan audit melalui tanda tangan digital kriptografi.

1.2. Tujuan Proyek

Pengembangan proyek SEEKEM memiliki beberapa tujuan utama.

- Menyediakan platform terpusat untuk pelaporan dan pencarian barang hilang maupun barang temuan di kampus IPB University.
- Mengimplementasikan kerangka keamanan AAA (Authentication, Authorization, Accounting) secara komprehensif pada arsitektur sistem.
- Melindungi data identitas pribadi (Personal Identifiable Information / PII) pengguna melalui enkripsi tingkat basis data.
- Memastikan integritas dan akuntabilitas sistem melalui penerapan tanda tangan digital kriptografi pada rekam jejak audit.
- Menyediakan mekanisme verifikasi klaim aman yang diawasi oleh pihak Administrator untuk mencegah manipulasi dan klaim palsu.

1.3. Ruang Lingkup

Laporan ini mencakup keseluruhan aspek teknis proyek SEEKEM, mulai dari arsitektur sistem, desain basis data, detail implementasi modul keamanan, alur kerja bisnis, hingga proses pengujian dan evaluasi sistem.

2. Arsitektur Sistem

2.1. Gambaran Umum Arsitektur

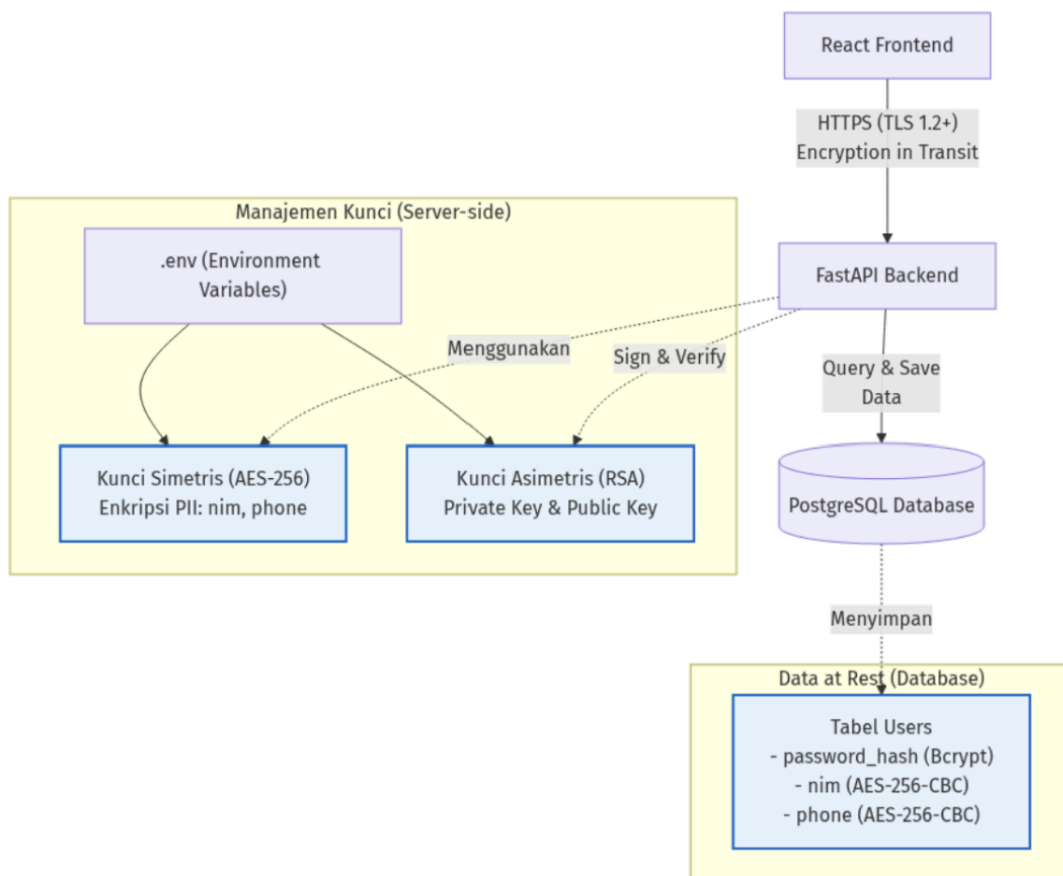
SEEKEM mengadopsi arsitektur Decoupled (Client-Server) dengan pemisahan tegas antara komponen antarmuka pengguna dan komponen server. Sistem juga menerapkan model Hybrid Peer-to-Peer (P2P) di mana penyerahan fisik barang dilakukan secara mandiri oleh para pihak, sementara sistem berperan sebagai mediator dan verifikator.

2.2. Komponen Sistem

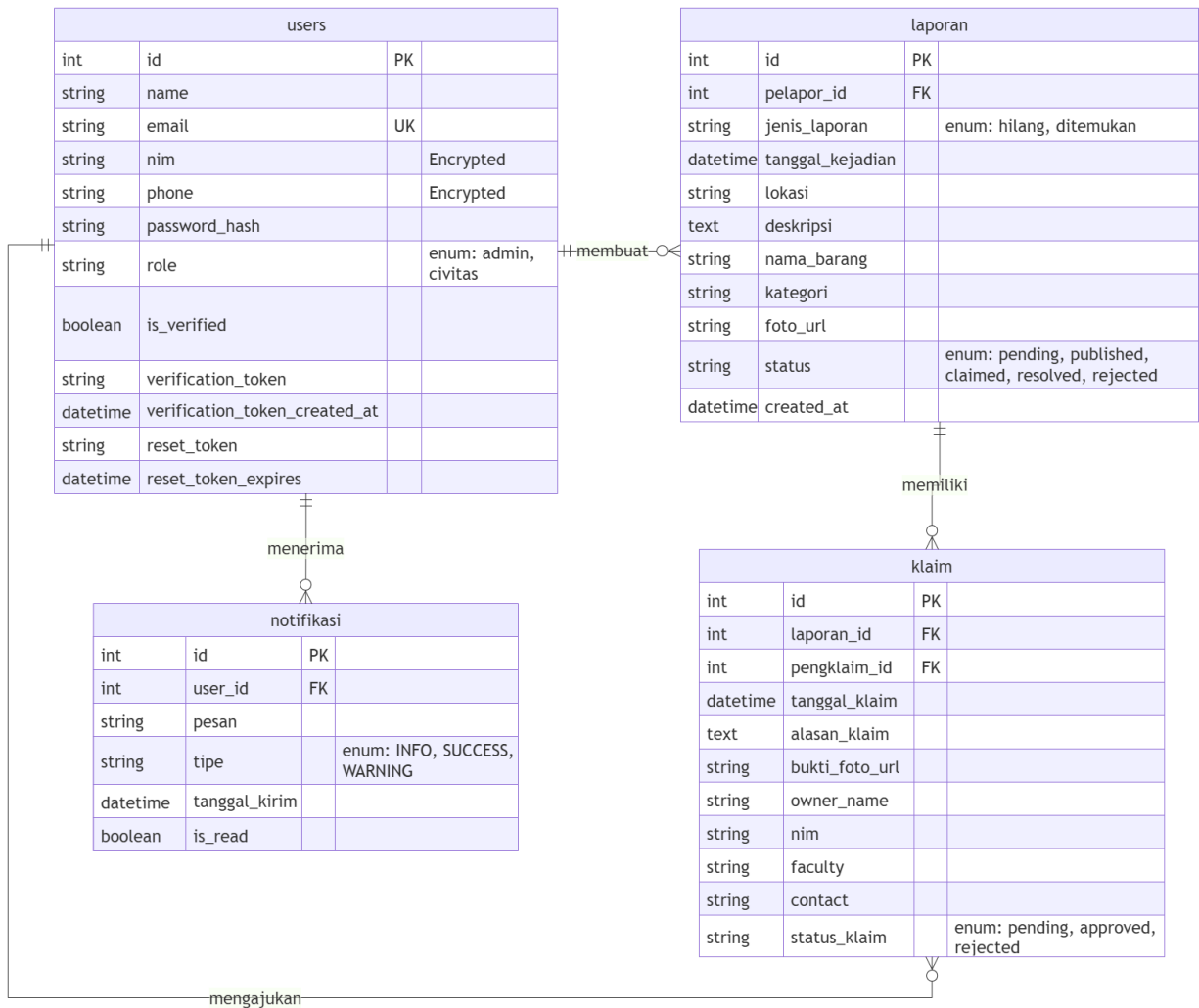
Berikut merupakan rincian komponen utama yang membangun arsitektur SEEKEM beserta teknologi yang digunakan pada masing-masing lapisan.

Lapisan	Teknologi	Peran dalam Sistem
Frontend (Client)	React.js 19, Vite 8, Zustand 5	Antarmuka pengguna berbasis SPA (Single Page Application).
Backend (API)	Python 3.9+, FastAPI 0.136, Uvicorn	Server RESTful API untuk pemrosesan logika bisnis.
Database	PostgreSQL 13+, SQLAlchemy 2.0 ORM	Penyimpanan data relasional dengan pemetaan objek.
Migrasi DB	Alembic 1.18	Manajemen perubahan skema basis data secara bertahap.
Penyimpanan Media	Cloudinary SDK	Hosting gambar bukti laporan dan klaim.
Notifikasi Surel	Google Apps Script Webhook, Jinja2	Pengiriman email asinkron untuk verifikasi dan pemberitahuan.
Keamanan	AES-256-GCM (PII), Ed25519 (Audit), JWT, Bcrypt	Enkripsi data, tanda tangan digital, autentikasi, dan hashing.

2.3. Diagram Arsitektur



3. Desain Basis Data (ERD)



4. Implementasi Keamanan

4.1. Kerangka AAA (Authentication, Authorization, Accounting)

4.1.1. Authentication (Autentikasi)

Sistem menerapkan autentikasi berlapis untuk memastikan keabsahan identitas pengguna.

- Pendaftaran akun dibatasi pada domain surel institusi (@apps.ipb.ac.id) sebagai simulasi Single Sign-On (SSO). Setiap pendaftar wajib melakukan verifikasi surel melalui tautan token yang memiliki masa aktif 24 jam.
- Sesi pengguna dikelola menggunakan JSON Web Token (JWT) dengan algoritma HMAC-SHA256 (HS256). Token disertakan pada setiap permintaan API melalui skema Bearer Token.
- Proses pemulihan kata sandi menggunakan token sekali pakai (one-time token) dengan masa aktif 15 menit, disertai mekanisme Rate Limiting (jeda minimum 60 detik) untuk mencegah penyalahgunaan.

- Kata sandi pengguna di-hash menggunakan algoritma Bcrypt secara satu arah (one-way hashing) sehingga tidak dapat dikembalikan ke bentuk aslinya.

4.1.2. Authorization (Otorisasi)

Kontrol akses berbasis peran (Role-Based Access Control / RBAC) diterapkan secara ketat dengan dua entitas peran.

- Peran civitas (Pengguna Umum) memiliki hak untuk membuat laporan, mengajukan klaim, dan berkomunikasi antar pengguna. Peran admin (Administrator) memiliki hak eksklusif untuk memverifikasi laporan, memvalidasi klaim, dan mengakses dasbor analitik beserta catatan audit.
- Proteksi endpoint API dilakukan melalui dua lapisan, yakni `get_current_user` untuk menjamin autentikasi pengguna yang sah, dan `get_current_active_admin` untuk membatasi akses hanya kepada Administrator.
- Perlindungan terhadap serangan Mass Assignment diimplementasikan melalui validasi skema Pydantic yang secara otomatis membuang parameter yang tidak diharapkan (misalnya penyisipan `role: admin` saat registrasi).
- Administrator secara sistemik diblokir dari membuat laporan publik maupun mengajukan klaim guna menjaga netralitas.

4.1.3. Accounting (Akuntabilitas)

Sistem pencatatan dan audit diterapkan secara menyeluruh untuk menjamin transparansi dan mencegah penyangkalan (non-repudiation).

- Tabel `activity_logs` mencatat seluruh transaksi fungsional (pembuatan laporan, pengajuan klaim, persetujuan) secara kronologis, meliputi identitas aktor, jenis aksi, dan stempel waktu.
- Tabel `audit_logs` mencatat aksi-aksi kritikal di tingkat server yang dilengkapi dengan tanda tangan digital kriptografi (Cryptographic Signature) untuk menjamin integritas setiap entri (diuraikan lebih lanjut pada Sub-bab 4.3).
- Setiap entri audit turut merekam metadata teknis seperti Alamat IP dan User-Agent peramban aktor untuk keperluan pelacakan forensik.

4.2. Enkripsi Data Sensitif (PII Protection)

Data identitas pribadi yang bersifat sensitif dilindungi menggunakan enkripsi tingkat basis data.

Algoritma yang Digunakan

Sistem menggunakan AES-256-GCM (Advanced Encryption Standard dalam mode Galois/Counter Mode) melalui pustaka `cryptography` Python. Algoritma ini memberikan perlindungan ganda berupa kerahasiaan (confidentiality) dan integritas data (authentication) secara bersamaan.

Mekanisme Implementasi

Implementasi dilakukan melalui kelas `EncryptedString`, sebuah tipe data kustom (TypeDecorator) pada lapisan ORM SQLAlchemy. Kelas ini secara transparan mengenkripsi data saat proses penulisan ke basis data (`process_bind_param`) dan mendekripsinya saat proses pembacaan (`process_result_value`).

Data yang Dienkripsi

- Kolom `phone` pada tabel `users` yang menyimpan nomor kontak WhatsApp pengguna.

- Kolom contact pada tabel klaim yang menyimpan nomor kontak pengklaim.

Format Penyimpanan

Data terenkripsi disimpan dengan prefiks `enc:v1:` diikuti oleh payload yang terdiri dari nonce (12 byte) dan ciphertext yang ter-encode dalam format URL-safe Base64. Kunci enkripsi (`FIELD_ENCRYPTION_KEY`) disimpan secara terpisah pada berkas variabel lingkungan (`.env`) dan tidak pernah diunggah ke repositori.

4.3. Tanda Tangan Digital Audit (Cryptographic Audit Signature)

Untuk menjamin integritas catatan audit dan mencegah manipulasi data (tampering) secara langsung di tingkat basis data, setiap entri pada tabel `audit_logs` dibubuhkan tanda tangan digital kriptografi.

Algoritma yang Digunakan

Sistem menggunakan algoritma Ed25519 (Edwards-curve Digital Signature Algorithm), sebuah skema tanda tangan kunci publik (public-key signature) yang dikenal karena keamanan tinggi, kecepatan komputasi yang efisien, serta ketahanan terhadap serangan side-channel.

Proses Penandatanganan (Signing)

Setiap kali sebuah entri audit baru diciptakan, sistem membentuk canonical payload berupa representasi JSON yang deterministik (kunci diurutkan, tanpa spasi berlebih) dari seluruh atribut log yang relevan. Payload tersebut kemudian ditandatangani menggunakan kunci privat Ed25519. Hasil tanda tangan di-encode dalam format URL-safe Base64 dan disimpan pada kolom `signature`.

Proses Verifikasi

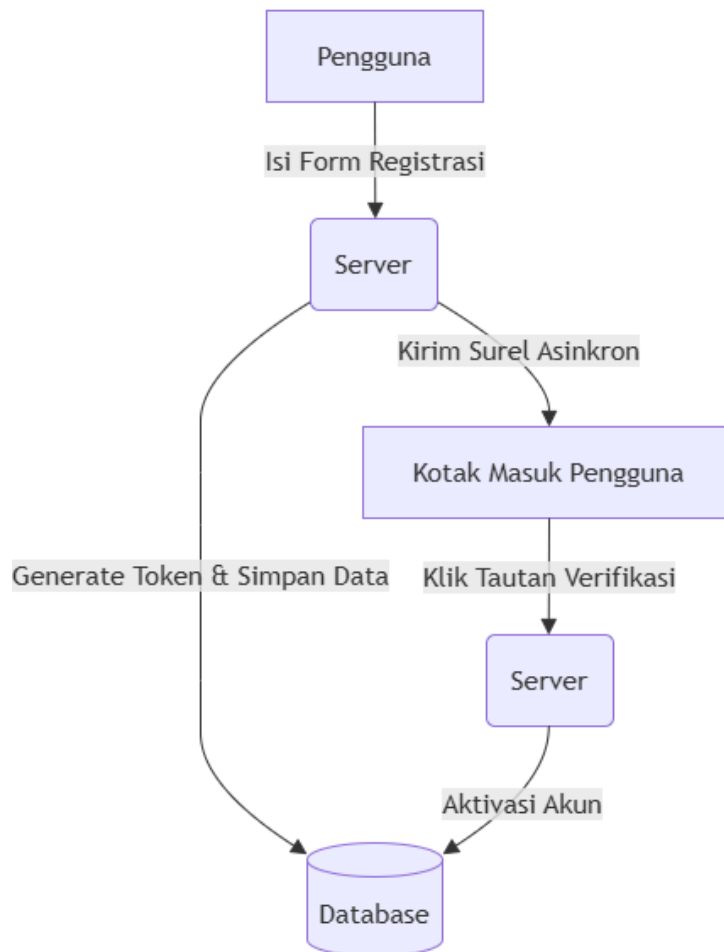
Verifikasi dilakukan dengan merekonstruksi canonical payload yang identik, kemudian memvalidasi tanda tangan menggunakan kunci publik yang berkorespondensi. Apabila isi entri log telah dimodifikasi secara manual (misalnya melalui akses langsung ke basis data), verifikasi akan gagal dan tanda tangan dinyatakan tidak valid.

Pasangan Kunci (Key Pair)

Pasangan kunci Ed25519 (kunci privat dan kunci publik) di-generate melalui skrip utilitas `generate_audit_signature_keys.py` dan disimpan sebagai variabel lingkungan (`AUDIT_SIGNATURE_PRIVATE_KEY` dan `AUDIT_SIGNATURE_PUBLIC_KEY`).

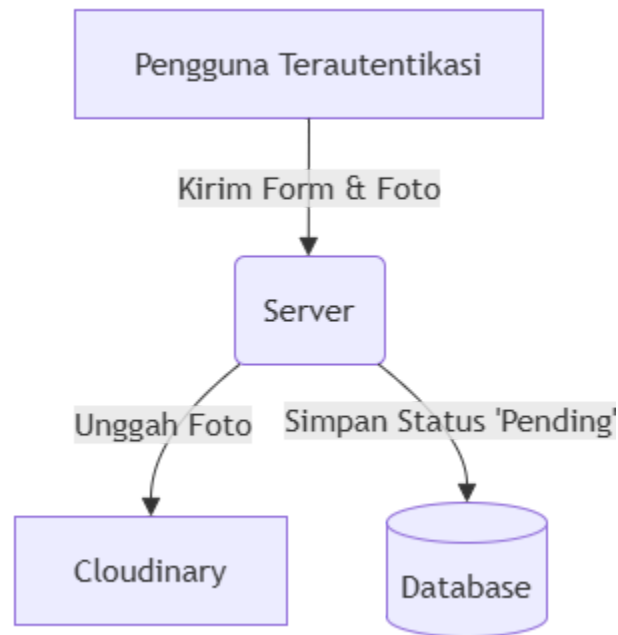
5. Alur Kerja Sistem (System Workflows)

5.1. Registrasi dan Verifikasi Akun



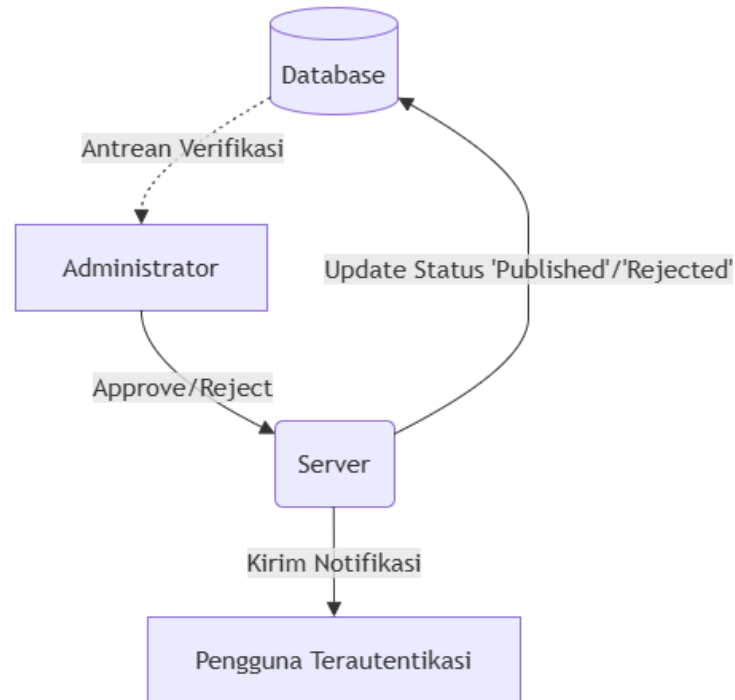
Pengguna mengisi formulir pendaftaran pada antarmuka web. Server menyimpan data pengguna dengan status belum terverifikasi dan men-generate token verifikasi. Surel berisi tautan verifikasi dikirimkan secara asinkron ke kotak masuk pendaftar. Pengguna mengklik tautan tersebut untuk mengaktifkan akunnya. Token memiliki masa aktif 24 jam dan dapat diminta ulang dengan jeda minimum 60 detik.

5.2. Pelaporan Barang



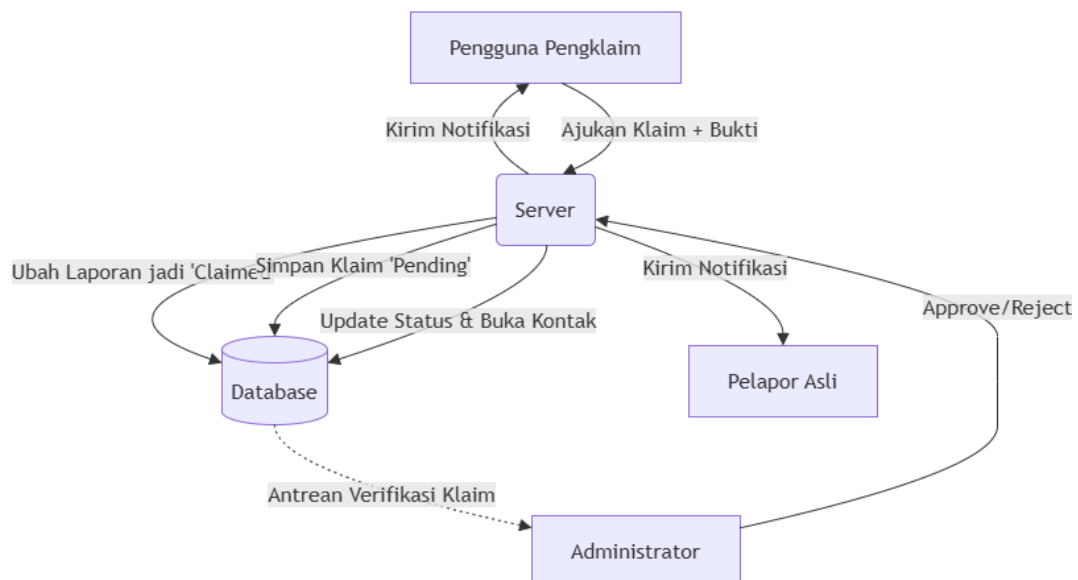
Pengguna yang telah terautentikasi mengisi formulir pelaporan yang mencakup informasi deskriptif dan foto bukti. Foto diunggah ke Cloudinary dan URL hasilnya disimpan bersama data laporan ke basis data dengan status awal pending. Laporan selanjutnya menunggu verifikasi oleh Administrator.

5.3. Verifikasi Laporan oleh Administrator



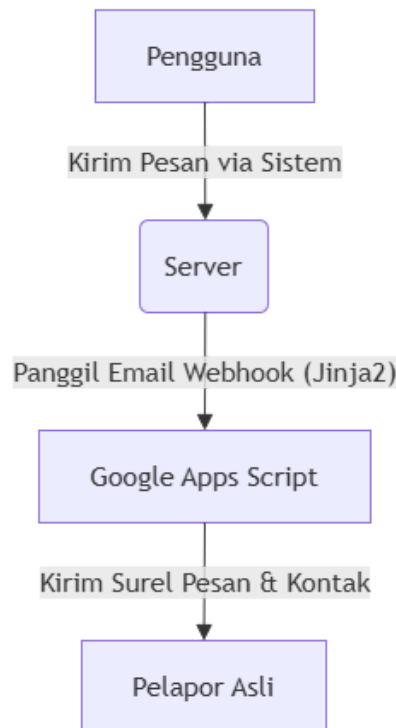
Administrator meninjau antrean laporan berstatus pending melalui dasbor khusus. Laporan yang dinilai layak disetujui dan statusnya diubah menjadi published, sehingga tampil di katalog publik. Laporan yang ditolak diberikan status rejected. Notifikasi otomatis dikirimkan kepada pelapor terkait.

5.4. Pengajuan dan Verifikasi Klaim



Pengguna yang menemukan barangnya di katalog dapat mengajukan klaim dengan menyertakan bukti kepemilikan. Status laporan berubah menjadi claimed untuk mencegah klaim ganda. Administrator memverifikasi bukti klaim. Apabila disetujui, informasi kontak kedua belah pihak (yang telah didekripsi) dibuka secara terkendali.

5.5. Komunikasi Antar Pengguna (P2P)



Setelah laporan berstatus published atau klaim berstatus approved, pengguna dapat menghubungi pelapor melalui fitur komunikasi. Sistem meneruskan pesan beserta kontak pengirim ke surel pelapor asli menggunakan templat HTML (Jinja2) melalui Webhook Google Apps Script.

6. Struktur Kode Sumber

6.1. Komponen Backend

Komponen server diorganisasikan menggunakan pola arsitektur berlapis (layered architecture) di dalam direktori 03_Source_Code/backend/app/.

Lapisan	Direktori	Isi dan Fungsi
Router/Controller	api/	10 modul endpoint yang menangani permintaan HTTP dari klien.

Konfigurasi	cores/	Pembacaan variabel lingkungan (config.py) dan inialisasi koneksi basis data (database.py).
Model Data	models/	7 definisi tabel ORM SQLAlchemy, termasuk User, Laporan, Klaim, Notifikasi, ActivityLog, dan AuditLog.
Skema Validasi	schemas/	9 modul validasi Pydantic untuk pengecekan data masukan dan format respons.
Logika Bisnis	services/	8 modul layanan, termasuk AuditLogService, EmailService, KlaimService, LaporanService, dan UploadService.
Templat	templates/	3 templat HTML Jinja2 untuk konten surel (verifikasi, reset password, notifikasi kontak).
Utilitas	utils/	Modul keamanan berisi fungsi hashing kata sandi dan pembuatan/verifikasi JWT.

6.2. Modul Keamanan Terpisah

Direktori	Isi dan Fungsi
database/	Modul enkripsi PII (encryption.py) berisi implementasi EncryptedString berbasis AES-256-GCM.
digital_signature/	Modul tanda tangan digital (audit_signature.py) berisi fungsi signing dan verifying menggunakan Ed25519, beserta skrip utilitas key generation.

7. Pengujian dan Verifikasi

7.1. Pengujian Fungsional

Pengujian fungsional dilakukan untuk memverifikasi bahwa setiap alur kerja berjalan sesuai dengan spesifikasi.

Skenario Pengujian	Hasil
Registrasi akun dengan domain @apps.ipb.ac.id	Berhasil membuat akun dengan status belum terverifikasi.
Verifikasi surel melalui tautan token	Akun berhasil diaktifkan setelah token valid diklik.
Login dengan kredensial valid	JWT berhasil di-generate dan dikembalikan ke klien.

Login sebelum verifikasi surel	Ditolak dengan kode HTTP 403 dan pesan informatif.
Pembuatan laporan barang	Data tersimpan dengan status pending dan foto terunggah ke Cloudinary.
Verifikasi laporan oleh Administrator	Status berubah menjadi published dan notifikasi terkirim.
Pengajuan klaim barang	Klaim tersimpan dan status laporan berubah menjadi claimed.
Persetujuan klaim oleh Administrator	Informasi kontak terbuka dan notifikasi terkirim ke kedua pihak.

7.2. Pengujian Keamanan

Pengujian keamanan dilakukan untuk memvalidasi efektivitas kontrol keamanan yang telah diimplementasikan.

Skenario Pengujian	Hasil
Penyisipan parameter role: admin saat registrasi	Parameter diabaikan oleh validasi Pydantic (Mass Assignment Protection).
Akses endpoint admin tanpa token JWT	Ditolak dengan kode HTTP 401 (Unauthorized).
Akses endpoint admin dengan token pengguna biasa	Ditolak dengan kode HTTP 403 (Forbidden).
Verifikasi tanda tangan audit log yang belum diubah	Verifikasi mengembalikan nilai True (valid).
Verifikasi tanda tangan setelah modifikasi manual data log	Verifikasi mengembalikan nilai False (tidak valid / terdeteksi tampering).
Pemeriksaan data phone dan contact di basis data	Data tersimpan dalam bentuk ciphertext dengan prefiks enc:v1:.
Permintaan ulang verifikasi surel kurang dari 60 detik	Ditolak oleh mekanisme Rate Limiting.

8. Kesimpulan

Proyek SEEKEM telah berhasil dikembangkan sebagai platform manajemen barang hilang dan temuan yang menerapkan prinsip keamanan informasi secara komprehensif. Implementasi kerangka AAA (Authentication, Authorization, Accounting) secara berlapis, perlindungan data PII melalui enkripsi AES-256-GCM, serta integritas catatan audit melalui tanda tangan digital Ed25519, secara bersama-sama

membentuk arsitektur pertahanan mendalam (Defense in Depth) yang melindungi sistem dari berbagai vektor ancaman.

Dengan pendekatan Hybrid Peer-to-Peer yang diawasi oleh Administrator sebagai verifikator, SEEKEM mampu menyeimbangkan antara kemudahan penggunaan bagi civitas akademika dan kebutuhan akan keamanan serta privasi data. Sistem ini diharapkan dapat menjadi solusi yang andal dan terpercaya untuk mengelola permasalahan barang hilang dan temuan di lingkungan kampus IPB University.